

DTOs and Validations in Spring Boot

1. The Real Problem

Suppose we are building a simple **Student Management Application**.

The application should support basic CRUD operations:

```
Create student
Get all students
Get student by ID
Update student
Delete student
```

For example, while creating a student, the client may send this request body:

```
{
  "name": "Amit",
  "email": "amit@gmail.com",
  "age": 21
}
```

Now the important backend question is:

When this request reaches our Spring Boot application, which layer receives it, which layer processes it, which layer talks to the database, and which layer returns the response?

This is where **layered architecture** becomes important.

2. Basic Layers in Our Current Project

In a simple Spring Boot CRUD project, we commonly work with these four parts:

Controller
Service
Repository
Entity

Layer	Main Responsibility
Controller	Handles HTTP requests and sends HTTP responses
Service	Contains business logic
Repository	Communicates with the database
Entity	Represents a database table

A clean backend application should keep these responsibilities separate.

3. Entity: The Class Connected to the Database

An **Entity** is a Java class mapped to a database table.

Example:

```
@Entity
public class Student {

    @Id
    @GeneratedValue(strategy = GenerationType.IDENTITY)
    private Long id;

    private String name;

    private String email;

    private Integer age;

    // getters and setters
}
```

Because of the `@Entity` annotation, JPA/Hibernate understands that this class should be mapped to a database table.

The class:

```
public class Student
```

can become a table like:

```
student
```

And its fields:

```
private Long id;  
private String name;  
private String email;  
private Integer age;
```

can become columns like:

```
id  
name  
email  
age
```

At the database level, the table may look like this:

id	name	email	age
1	Amit	amit@gmail.com	21
2	Neha	neha@gmail.com	22

The first important point is:

| Entity is mainly designed to represent the database structure.

4. Complete Create API Flow

In a normal create API, the flow looks like this:

```
Client
  ↓
Controller
  ↓
Service
  ↓
Repository
  ↓
Database
```

Example flow:

1. Client sends POST request with JSON data.
2. Controller receives the request.
3. Spring/Jackson converts JSON into a Java object.
4. Controller calls the Service layer.
5. Service applies business logic.
6. Service calls Repository.
7. Repository saves data into the database.
8. Database returns saved data.
9. Service prepares the response.
10. Controller sends the HTTP response back to the client.

This flow is correct.

The problem starts when we use the **same Entity class everywhere**.

Part 1: Problem With Passing Entity Everywhere

5. Current Problem

In a beginner CRUD project, we often pass the `Student` entity everywhere:

```
Controller → Service → Repository → Database
```

The same `Student` entity may be used for:

1. Representing the database table
2. Receiving request data
3. Moving data through the service layer
4. Getting saved by the repository
5. Returning API response

For a small demo project, this works.

But in real-world applications, this becomes a bad design.

6. Two Worlds in a Backend Application

A backend application mainly deals with two worlds:

```
Outside World → API Request / API Response
Inside World  → Database / Business Logic
```

The **outside world** can be:

```
Frontend
Mobile app
Postman
Third-party client
Another backend service
```

The **inside world** contains:

```
Database tables
Entity classes
Repository layer
Business logic
Internal fields
```

The key principle is:

The outside world should not directly control or depend on the internal database structure.

But when we accept and return entities directly, we start exposing the internal structure of our application.

7. Entity Has a Specific Purpose

An Entity is created mainly for database mapping.

It belongs to the internal side of the application because it is closely connected to:

```
Database table
Columns
Primary key
Relationships
Hibernate/JPA
```

On the other hand, request and response objects belong to the external API side.

So a clean separation should be:

```
Entity          → Internal database model
Request/Response → External API model
```

But when we pass Entity everywhere, we are doing this:

```
Entity = Database model
Entity = Request model
Entity = Response model
```

This is the root problem.

8. Problem 1: Client Can Send Fields They Should Not Send

Suppose our `Student` entity has internal fields:

```
@Entity
public class Student {

    @Id
    @GeneratedValue(strategy = GenerationType.IDENTITY)
    private Long id;

    private String name;

    private String email;

    private Integer age;

    private Boolean isDeleted = false;

    private LocalDateTime createdAt;

    private LocalDateTime updatedAt;
}
```

Now the controller accepts the entity directly:

```
@PostMapping
public Student createStudent(@RequestBody Student student) {
    return studentService.createStudent(student);
}
```

The client is supposed to send only this:

```
{
  "name": "Amit",
  "email": "amit@gmail.com",
  "age": 21
}
```

But because the controller directly accepts `Student`, the client may send extra fields:

```
{
  "id": 100,
  "name": "Amit",
  "email": "amit@gmail.com",
  "age": 21,
  "isDeleted": true,
  "createdAt": "2026-07-04T10:00:00",
  "updatedAt": "2026-07-04T10:00:00"
}
```

This is a design problem.

The client should not decide values like:

```
id
isDeleted
createdAt
updatedAt
internal status fields
```

These fields should be controlled by the backend.

So the first problem is:

| Entity exposes internal fields to the outside world.

9. Problem 2: Client Can Modify Sensitive/Internal Data

Later, suppose the entity grows and contains more fields:

```
@Entity
public class Student {

    @Id
```


Coder Army

```
@GeneratedValue(strategy = GenerationType.IDENTITY)
private Long id;

private String name;

private String email;

private String password;

private Boolean isDeleted;

private Boolean isVerified;

private String role;

private String internalRemark;

private LocalDateTime createdAt;
}
```

Now imagine the client sends this during update:

```
{
  "name": "Amit",
  "email": "amit@gmail.com",
  "age": 21,
  "role": "ADMIN",
  "isVerified": true,
  "isDeleted": false
}
```

This is dangerous.

The user should not be able to make themselves:

```
ADMIN
verified
not deleted
approved
premium
```

These values should be controlled by business logic, not by the client.

This problem is commonly called the **mass assignment problem**.

In simple words:

The client sends more data than required, and the backend accidentally accepts it.

10. Problem 3: Response May Leak Unwanted Data

Suppose the entity contains fields like:

```
private String password;
private Boolean isDeleted;
private String internalRemark;
private LocalDateTime createdAt;
```

And the controller returns the entity directly:

```
@GetMapping("/{id}")
public Student getStudentById(@PathVariable Long id) {
    return studentService.getStudentById(id);
}
```

The API response may accidentally expose internal or sensitive fields.

The client usually does not need fields like:

```
password
isDeleted
internalRemark
```

```
internal flags  
backend-only metadata
```

So another problem is:

Returning Entity directly can leak unwanted internal data.

11. Problem 4: Request and Response Usually Need Different Structures

In real projects, the data received from the client and the data returned to the client are often different.

For creating a student, the client may send:

```
{  
  "name": "Amit",  
  "email": "amit@gmail.com",  
  "age": 21  
}
```

But after creating the student, the API may return:

```
{  
  "id": 1,  
  "name": "Amit",  
  "email": "amit@gmail.com",  
  "message": "Student created successfully"  
}
```

The request does not need `id` or `message`.

The response may need `id` and `message`.

So request and response should not always use the same class.

12. Problem 5: Database Changes Can Break the API Contract

Suppose the current entity is:

```
@Entity
public class Student {

    private Long id;

    private String name;

    private String email;

    private Integer age;
}
```

The frontend may be expecting this response:

```
{
  "id": 1,
  "name": "Amit Sharma",
  "email": "amit@gmail.com",
  "age": 21
}
```

Later, for database design reasons, we split `name` into two fields:

```
private String firstName;
private String lastName;
```

If we return Entity directly, the API response may also change:

```
{
  "id": 1,
```

```
"firstName": "Amit",  
"lastName": "Sharma",  
"email": "amit@gmail.com",  
"age": 21  
}
```

But the frontend may still be expecting:

```
{  
  "id": 1,  
  "name": "Amit Sharma",  
  "email": "amit@gmail.com",  
  "age": 21  
}
```

This means one internal database change can break the external API contract.

A good API should not break just because the database structure changed internally.

13. Main Design Issue

A class should ideally have one clear responsibility.

But when we pass Entity everywhere, the Entity becomes responsible for too many things:

```
Database mapping  
Request handling  
Response handling  
Business data transfer  
External API contract
```

This is why we introduce DTOs.

Part 2: DTOs14. What is a DTO?

DTO stands for:

Data Transfer Object

A DTO is a simple object used to transfer data between layers or between client and server.

Simple meaning:

■ DTO is used to carry only the data required for a particular request or response.

DTO is not created for database mapping.

Class Type	Main Purpose
Entity	Represents database table
DTO	Transfers data in request/response or between layers

15. Types of DTOs

In a normal CRUD project, we commonly create two main types of DTOs:

Request DTO
Response DTO

In real projects, we may create more specific DTOs:

CreateStudentRequestDto
UpdateStudentRequestDto
StudentResponseDto
StudentSummaryResponseDto
StudentDetailResponseDto

For a beginner project, we can start with:

StudentRequestDto

16. Where Should DTOs Be Created?

A common package structure is:

```
src/main/java/com/example/studentapp
├── controller
├── service
├── repository
├── entity
└── dto
```

The `dto` package contains request and response DTO classes.

17. Request DTO

A **Request DTO** represents the data that the client is allowed to send to the API.

It is part of the API contract.

Example:

```
public class StudentRequestDto {

    private String name;

    private String email;

    private Integer age;

    // getters and setters
}
```

Now the controller can receive this DTO instead of the Entity:

Coder Army

```
@PostMapping
public StudentResponseDto createStudent(@RequestBody StudentRequestDto requestDto) {
    return studentService.createStudent(requestDto);
}
```

This clearly says:

```
For creating a student, the client can send only:
name
email
age
```

The Request DTO protects the API boundary.

It prevents the client from directly controlling internal database fields.

18. Response DTO

A **Response DTO** represents the data that the API wants to send back to the client.

Example:

```
public class StudentResponseDto {

    private Long id;

    private String name;

    private String email;

    private Integer age;

    private String message;
```



```
// getters and setters  
}
```

This DTO allows us to decide exactly what should be visible in the API response.

19. Better Response Structure

Instead of mixing student data and message in the same level, we can also create a cleaner response structure.

Example:

```
{  
  "studentInfo": {  
    "id": 1,  
    "name": "Amit",  
    "email": "amit@gmail.com",  
    "age": 21  
  },  
  "message": "Student created successfully"  
}
```

For this, we can create separate response classes.

```
public class CreateStudentResponseDto {  
  
    private StudentInfoDto studentInfo;  
  
    private String message;  
  
    // getters and setters  
}
```

```
public class StudentInfoDto {
```

```
private Long id;

private String name;

private String email;

private Integer age;

// getters and setters
}
```

This gives a more professional and structured API response.

20. DTO Naming Convention

For beginners, simple names are fine:

```
StudentRequestDto
StudentResponseDto
```

In real projects, more specific names are better:

```
CreateStudentRequestDto
UpdateStudentRequestDto
StudentResponseDto
StudentDetailsResponseDto
StudentListResponseDto
```

Reason:

└ Different APIs may require different request and response structures.

For example, create request may allow email:

```
public class CreateStudentRequestDto {
```

```
private String name;

private String email;

private Integer age;
}
```

But update request may not allow changing email:

```
public class UpdateStudentRequestDto {

    private String name;

    private Integer age;
}
```

This is the power of DTOs.

They allow each API to define its own contract clearly.

Part 3: Manual DTO Mapping

21. Why Mapping Is Required

DTO and Entity are two different classes.

So we need to convert one into another.

There are two common mappings:

```
StudentRequestDto → Student Entity
Student Entity    → StudentResponseDto
```

22. Mapping 1: Request DTO to Entity

When the client sends data, the controller receives `StudentRequestDto`.

But the repository cannot save `StudentRequestDto`.

The repository saves the Entity.

So we convert:

```
StudentRequestDto → Student
```

Example:

```
private Student mapToEntity(StudentRequestDto requestDto) {
    Student student = new Student();

    student.setName(requestDto.getName());
    student.setEmail(requestDto.getEmail());
    student.setAge(requestDto.getAge());

    return student;
}
```

23. Mapping 2: Entity to Response DTO

After saving or fetching data from the database, we get a `Student` entity.

But we do not want to return the Entity directly.

So we convert:

```
Student → StudentResponseDto
```

Example:

```
private StudentResponseDto mapToResponseDto(Student student)
{
    StudentResponseDto responseDto = new StudentResponseDto
```

```
( );

responseDto.setId(student.getId());
responseDto.setName(student.getName());
responseDto.setEmail(student.getEmail());
responseDto.setAge(student.getAge());

return responseDto;
}
```

24. Where Should Mapping Happen?

For a beginner project, mapping can be done inside the **Service layer**.

Reason:

```
Controller side → DTO
Repository side → Entity
```

The Service layer sits between the Controller and Repository.

So it can work as the bridge:

```
Controller
  ↓ DTO
Service
  ↓ Entity
Repository
```

The Controller should not know too much about Entity.

The Repository should not know anything about DTO.

That is why the Service layer is a clean place for mapping in a beginner project.

In larger projects, we can create a separate mapper class or use mapping libraries like MapStruct.

Part 4: Updating CRUD APIs With DTOs

25. Create API With DTO

Controller:

```
@PostMapping
public StudentResponseDto createStudent(@RequestBody StudentRequestDto requestDto) {
    return studentService.createStudent(requestDto);
}
```

Service:

```
public StudentResponseDto createStudent(StudentRequestDto requestDto) {
    Student student = mapToEntity(requestDto);

    Student savedStudent = studentRepository.save(student);

    return mapToResponseDto(savedStudent);
}
```

Flow:

```
Client JSON
↓
StudentRequestDto
↓
Student Entity
↓
Database
↓
Student Entity
↓
StudentResponseDto
```

↓
Client Response

26. Get All Students API With DTO

Controller:

```
@GetMapping
public List<StudentResponseDto> getAllStudents() {
    return studentService.getAllStudents();
}
```

Service:

```
public List<StudentResponseDto> getAllStudents() {
    List<Student> students = studentRepository.findAll();

    return students.stream()
        .map(this::mapToResponseDto)
        .toList();
}
```

Here, for every `Student` entity, we call:

```
mapToResponseDto(student)
```

So the API returns a list of response DTOs instead of a list of entities.

27. Get Student By ID API With DTO

Controller:

```
@GetMapping("/{id}")
public StudentResponseDto getStudentById(@PathVariable Long id) {
```

```
        return studentService.getById(id);
    }
}
```

Service:

```
public StudentResponseDto getById(Long id) {
    Student student = studentRepository.findById(id)
        .orElseThrow(() -> new RuntimeException("Student
not found"));

    return mapToResponseDto(student);
}
```

The Repository returns Entity.

The Service converts Entity into Response DTO.

The Controller returns only the DTO.

28. Update API With DTO

Controller:

```
@PutMapping("/{id}")
public StudentResponseDto updateStudent(
    @PathVariable Long id,
    @RequestBody StudentRequestDto requestDto) {

    return studentService.updateStudent(id, requestDto);
}
```

Service:

```
public StudentResponseDto updateStudent(Long id, StudentReque
stDto requestDto) {
    Student existingStudent = studentRepository.findById(id)
        .orElseThrow(() -> new RuntimeException("Student
```



```
not found"));
```

```
existingStudent.setName(requestDto.getName());  
existingStudent.setEmail(requestDto.getEmail());  
existingStudent.setAge(requestDto.getAge());
```

```
Student updatedStudent = studentRepository.save(existingStudent);
```

```
return mapToResponseDto(updatedStudent);  
}
```

Important point:

We do not create a completely new entity during update. We first fetch the existing entity, update allowed fields, save it again, and return a response DTO.

29. Delete API and DTO

For delete APIs, many projects return only a message.

Example:

```
@DeleteMapping("/{id}")  
public String deleteStudent(@PathVariable Long id) {  
    studentService.deleteStudent(id);  
    return "Student deleted successfully";  
}
```

A more professional response can be:

```
{  
    "message": "Student deleted successfully"  
}
```

For that, we can create a simple response DTO:

```
public class ApiResponseDto {

    private String message;

    // getters and setters

}
```

Part 5: Validations30. Why Validation Is Needed

Whenever a backend receives data from outside, the data is not guaranteed to be correct.

The client may send invalid data:

```
{
  "name": "",
  "email": "wrong-email",
  "age": -5
}
```

Or:

```
{
  "name": "A",
  "email": "",
  "age": null
}
```

This data should not directly reach the service layer or database.

Without validation, bad data may get stored:

id	name	email	age
1		wrong-email	-5

This is not meaningful student data.

Validation means:

Before accepting request data, check whether the data follows the rules of the application.

31. Without Validation

Controller:

```
@PostMapping
public StudentResponseDto createStudent(@RequestBody StudentRequestDto requestDto) {
    return studentService.createStudent(requestDto);
}
```

Without validation, invalid data can reach the service layer.

Then the service maps it to Entity.

Then the repository saves it.

That means bad input can enter the system.

32. With Validation

We want rules like:

```
name should not be blank
name should have at least 2 characters
email should not be blank
email should be valid
age should not be null
age should be at least 18
```

Correct flow:

Client sends JSON
↓
Controller receives request
↓
Validation happens
↓
If valid → Service method runs
If invalid → Error response goes back

Validation protects the service layer and database from invalid input.

33. Adding Validation Dependency

In Spring Boot, validation support usually comes from this dependency:

```
<dependency>  
  <groupId>org.springframework.boot</groupId>  
  <artifactId>spring-boot-starter-validation</artifactId>  
</dependency>
```

If we are using Spring Initializr, we can add this by selecting:

Validation

34. Common Validation Annotations

Validation annotations are placed on fields.

Example:

```
@NotBlank  
private String name;
```

This means:

name cannot be null, empty, or only spaces

Common validation annotations:

Annotation	Used For	Meaning
<code>@NotNull</code>	Any object	Value cannot be <code>null</code>
<code>@NotBlank</code>	String	Value cannot be <code>null</code> , empty, or only spaces
<code>@NotEmpty</code>	String, Collection, Array	Value cannot be <code>null</code> or empty
<code>@Email</code>	String	Value should be a valid email format
<code>@Min(value)</code>	Number	Minimum allowed value
<code>@Max(value)</code>	Number	Maximum allowed value
<code>@Size(min, max)</code>	String, Collection	Length or size should be within range
<code>@Pattern(regex)</code>	String	Value should match a regex pattern
<code>@Positive</code>	Number	Value should be positive
<code>@Past</code>	Date/time	Date should be in the past
<code>@Future</code>	Date/time	Date should be in the future

35. `@NotNull` vs `@NotBlank` vs `@NotEmpty` `@NotNull`

Example:

```
@NotNull
private Integer age;
```

This checks only one thing:

age should not be null

Invalid:

```
{
  "age": null
}
```

For numbers like `Integer`, `Long`, `Double`, etc., `@NotNull` is useful.

But for strings, `@NotNull` is often not enough because this is not null:

```
{
  "name": ""
}
```

`@NotBlank`

Example:

```
@NotBlank
private String name;
```

This rejects:

```
{
  "name": null
}
```

```
{
  "name": ""
}
```

```
{
  "name": " "
}
```

For fields like name, email, title, city, etc., `@NotBlank` is usually better.

@NotEmpty

Example:

```
@NotEmpty
private List<String> subjects;
```

This checks that the value is not null and not empty.

Invalid:

```
{
  "subjects": []
}
```

For normal strings, prefer `@NotBlank`.

For lists, arrays, and collections, `@NotEmpty` is useful.

36. Where Should We Add Validations?

A common question is:

```
Should validations be added in Entity or Request DTO?
```

For request validation, validations should be added in the **Request DTO**.

Reason:

| Validation rules are about what the client is allowed to send.

The client sends request data, so request validation naturally belongs to the Request DTO.

37. Updated Student Request DTO With Validations

```
import jakarta.validation.constraints.Email;
import jakarta.validation.constraints.Max;
import jakarta.validation.constraints.Min;
import jakarta.validation.constraints.NotBlank;
import jakarta.validation.constraints.NotNull;
import jakarta.validation.constraints.Size;

public class StudentRequestDto {

    @NotBlank(message = "Student name is required")
    @Size(min = 2, max = 50, message = "Student name must be
between 2 and 50 characters")
    private String name;

    @NotBlank(message = "Student email is required")
    @Email(message = "Student email should be valid")
    private String email;

    @NotNull(message = "Student age is required")
    @Min(value = 18, message = "Student age must be at least
18")
    @Max(value = 60, message = "Student age must not be great
er than 60")
    private Integer age;

    // getters and setters
}
```

This DTO clearly defines the rules:

```
name cannot be blank
name length should be between 2 and 50 characters
email cannot be blank
email should be valid
```


age cannot be null
age should be between 18 and 60

38. Using `@Valid` in Controller

Adding validation annotations in the DTO is not enough.

To trigger validation for request body data, we use `@Valid` in the controller.

```
import jakarta.validation.Valid;

@PostMapping
public StudentResponseDto createStudent(
    @Valid @RequestBody StudentRequestDto requestDto) {

    return studentService.createStudent(requestDto);
}
```

Now Spring validates `StudentRequestDto` before calling the service method.

Same thing can be done for update API:

```
@PutMapping("/{id}")
public StudentResponseDto updateStudent(
    @PathVariable Long id,
    @Valid @RequestBody StudentRequestDto requestDto) {

    return studentService.updateStudent(id, requestDto);
}
```

Important line:

```
@Valid @RequestBody StudentRequestDto requestDto
```

Meaning:

@RequestBody → Convert JSON into Java object
@Valid → Apply validation rules on that Java object

39. What Happens Internally During Validation?

Suppose the client sends:

```
POST /api/students
```

Request body:

```
{
  "name": "",
  "email": "wrong-email",
  "age": 15
}
```

Spring performs these steps:

1. JSON is converted into StudentRequestDto.
2. Because @Valid is present, Spring checks validation annotations.
3. It checks name.
name is blank, so validation fails.
4. It checks email.
email format is invalid, so validation fails.
5. It checks age.
age is less than 18, so validation fails.
6. Service method is not called.
7. Error response goes back to the client.

Key point:

| If validation fails, the request does not reach the service layer.

So validation protects both business logic and database from bad input.

40. Validation Annotations vs `@Valid`

Both parts are important.

```
@NotBlank  
@Email  
@Min  
@Max  
@Size
```

These annotations define the rules.

```
@Valid
```

This tells Spring to apply those rules.

So:

```
Validation annotations define the rules.  
@Valid triggers the validation process.
```

Part 6: Default Validation Error Response

41. What Status Code Is Returned When Validation Fails?

When validation fails, Spring Boot returns:

```
HTTP 400 Bad Request
```

Why `400` ?

Because the client sent invalid request data.

The server is working fine.

The problem is with the request body.

So validation failure is not:

```
500 Internal Server Error
```

It is:

```
400 Bad Request
```

42. Why Default Error Response Is Not Good Enough

The default error response is technically correct, but it is not always clean or frontend-friendly.

Frontend usually wants a simple response like this:

```
{
  "name": "Student name is required",
  "email": "Student email should be valid",
  "age": "Student age must be at least 18"
}
```

Or a more structured response like this:

```
{
  "success": false,
  "message": "Validation failed",
  "errors": {
    "name": "Student name is required",
    "email": "Student email should be valid",
    "age": "Student age must be at least 18"
  }
}
```

```
}  
}
```

Spring Boot may not give this exact clean format automatically.

That is why we later use:

```
Global Exception Handling
```

Global Exception Handling allows us to control the exact error response format.

43. Custom Validation Messages

Without a custom message:

```
@NotBlank  
private String name;
```

Spring may return a default message like:

```
must not be blank
```

This works, but it is generic.

A better approach is to write a clear custom message:

```
@NotBlank(message = "Student name is required")  
private String name;
```

Another example:

```
@Email(message = "Student email should be valid")  
private String email;
```

Custom messages make validation errors easier to understand for frontend developers and API users.

Part 7: Final Clean Flow

44. Final Create API Flow With DTO and Validation

```

Client sends JSON
↓
Controller receives StudentRequestDto
↓
@Valid checks request data
↓
If invalid:
    return 400 Bad Request
↓
If valid:
    Service method runs
↓
Service maps StudentRequestDto to Student Entity
↓
Repository saves Student Entity
↓
Service maps saved Student Entity to StudentResponseDto
↓
Controller returns response DTO

```

This is a cleaner and more professional API design.

45. Entity vs DTO Summary

Point	Entity	DTO
Main purpose	Database mapping	Data transfer
Belongs to	Internal application side	API/request-response side
Connected with	JPA, Hibernate, database table	Controller, request body, response body
Should client control it?	No	Yes, in a limited and controlled way
Can contain internal fields?	Yes	Should contain only required fields

Point	Entity	DTO
Example	<code>Student</code>	<code>StudentRequestDto</code> , <code>StudentResponseDto</code>

46. Request DTO vs Response DTO Summary

Point	Request DTO	Response DTO
Direction	Client to server	Server to client
Represents	What client can send	What API returns
Example	<code>StudentRequestDto</code>	<code>StudentResponseDto</code>
Usually contains	Input fields	Output fields
Validation	Usually added here	Usually not needed for normal response

47. Important Takeaways

- Entity is mainly for database mapping.
- DTO is mainly for data transfer.
- Request DTO defines what the client is allowed to send.
- Response DTO defines what the API will return.
- Passing Entity everywhere exposes internal database structure.
- DTOs help protect the API boundary.
- DTOs prevent accidental exposure of sensitive/internal fields.
- DTOs help maintain a stable API contract even if the database changes.
- Validation should be added on Request DTOs.
- `@Valid` is required in the controller to trigger validation.
- Invalid request data should return `400 Bad Request` , not `500 Internal Server Error` .
- Custom validation messages make APIs easier to use.
- For a beginner project, manual mapping inside the Service layer is acceptable.

- In larger projects, mapping can be moved to a separate mapper class.

48. Suggested Teaching Ending

DTOs and validations make a CRUD API more professional.

Without DTOs, the API directly exposes the database model.

Without validations, bad data can enter the system.

With DTOs and validations, the application becomes cleaner:

```
Controlled request data
Clean response data
Protected internal model
Better API contract
Better error handling
```

The next natural topic after this is:

```
Global Exception Handling
```

That is where we customize validation errors and other exceptions into a clean, consistent response format.